

FORMATIF 1
AUDIT SISTEM INFORMASI



Disusun oleh:

Rama Pramudya Wibisana

2022320019

PROGRAM STUDI SISTEM INFORMASI

FAKULTAS INFORMATIKA

UNIVERSITAS BINA INSANI

BEKASI

2024

1. Beberapa komponen utama dalam lingkungan TI yang perlu diaudit meliputi:

- **Infrastruktur Jaringan:** Audit jaringan mengevaluasi konfigurasi firewall, enkripsi jaringan, dan kebijakan keamanan untuk mencegah peretasan atau serangan siber. Audit ini memastikan bahwa perangkat jaringan organisasi, seperti firewall, router, switch, dan perangkat lainnya, aman dan terlindungi dari akses yang tidak sah. Seringkali, kerentanan jaringan ditemukan melalui pengujian penetrasi.
- **Perangkat Keras (Hardware):** Pemeriksaan perangkat keras mencakup evaluasi perangkat fisik yang digunakan untuk memastikan bahwa mereka dalam kondisi baik, dilindungi secara fisik, dan dipantau untuk mencegah akses fisik yang tidak sah. Misalnya, server, workstation, dan perangkat penyimpanan lainnya dievaluasi untuk melihat apakah mereka memiliki kontrol keamanan fisik, seperti kunci akses atau sistem pengawasan.
- **Sistem Aplikasi:** Aplikasi yang digunakan oleh organisasi harus dievaluasi untuk memastikan bahwa mereka berfungsi dan aman. Auditor memeriksa apakah aplikasi tersebut aman, mematuhi peraturan, dan bebas dari kerentanan. Pengujian keamanan, integritas data, dan fungsi logis aplikasi dapat dilakukan dalam tes ini untuk memastikan bahwa aplikasi tersebut beroperasi sebagaimana mestinya.
- **Basis Data:** Database menyimpan data sensitif dan penting bagi organisasi. Auditor memeriksa pengelolaan akses, keamanan, dan pemulihan database. Kontrol akses yang ketat, enkripsi data sensitif, dan mekanisme pemulihan dan pemulihan yang kuat diperlukan untuk mencegah kehilangan atau pencurian data.
- **Keamanan Fisik:** Selain aspek digital, infrastruktur fisik juga harus diaudit untuk mencegah ancaman fisik seperti pencurian, bencana alam, atau akses yang tidak sah. Contoh pengamanan fisik termasuk kamera pengawas (CCTV), kontrol akses pintu dengan kunci atau kartu, dan sistem pencegahan kebakaran.
- **Proses Manajemen TI:** Ini mencakup tata kelola dan prosedur yang mengatur TI dalam organisasi. Ini termasuk kebijakan tentang penggunaan perangkat, backup,

dan pemulihan bencana, serta keamanan siber. Auditor juga memastikan bahwa prosedur ini dilakukan sesuai dengan peraturan dan standar, dan apakah ada perencanaan pemulihan cepat jika terjadi kegagalan sistem.

2. Langkah-langkah dalam proses audit TI biasanya meliputi:

- **Perencanaan Audit:** Pada tahap awal, auditor menentukan tujuan audit, ruang lingkup, dan topik khusus yang akan dibahas. Ini termasuk identifikasi risiko utama dan topik mana yang paling penting untuk audit. Misalnya, audit sistem yang menangani data sensitif mungkin berkonsentrasi pada keamanan data, sedangkan audit jaringan mungkin berkonsentrasi pada menjaga akses ke jaringan.
- **Pengumpulan Informasi:** Auditor memeriksa kebijakan TI, prosedur, konfigurasi sistem, dan dokumentasi lainnya. Mereka juga bertanya kepada personel yang relevan untuk mendapatkan pemahaman yang lebih baik tentang kontrol TI yang digunakan dan operasi harian.
- **Evaluasi Risiko dan Pengujian Kontrol:** Auditor menilai risiko yang ada dalam sistem dan menguji kontrol yang digunakan untuk mengelola risiko tersebut. Mereka menguji kebijakan keamanan, proses login, dan mekanisme perlindungan lainnya untuk memastikan bahwa kontrol berfungsi dengan baik. Untuk menemukan kelemahan, pengujian penetrasi dan pemantauan aktivitas dapat digunakan dalam pengujian ini.
- **Pelaporan:** Setelah audit selesai, auditor membuat laporan yang mencatat hasil, masalah, dan solusi. Laporan ini disampaikan kepada manajemen dan biasanya mencakup risiko potensial dan cara meningkatkan keamanan dan kepatuhan terhadap regulasi.
- **Tindak Lanjut:** Auditor akan melakukan tindakan lanjut untuk memastikan organisasi menerapkan saran. Ini sangat penting untuk segera memperbaiki kesalahan dan mengurangi risiko.

3. Undang-Undang Informasi dan Transaksi Elektronik (UU ITE) adalah undang-undang nasional yang mengatur transaksi elektronik, privasi data, dan keamanan siber. Berikut adalah manfaat UU ITE untuk audit sistem informasi:

- **Kepastian Hukum untuk Transaksi Digital:** UU ITE memberikan kepastian hukum terkait transaksi digital dan elektronik, melindungi hak-hak pengguna dalam transaksi online, dan menjamin keabsahan kontrak elektronik. Audit ini membantu organisasi mematuhi peraturan dan menjaga kepercayaan dalam transaksi elektronik.
- **Perlindungan Data Pribadi:** UU ITE mencakup perlindungan data pengguna. Auditor akan memeriksa apakah sistem informasi organisasi memiliki mekanisme untuk melindungi data pengguna, seperti enkripsi dan kontrol akses. Ini penting untuk mematuhi UU ITE agar organisasi tidak terkena denda atau hukuman.
- **Kewajiban Keamanan:** Auditor memastikan bahwa organisasi telah menerapkan kebijakan dan prosedur keamanan yang sesuai untuk mencegah akses ilegal atau pelanggaran data sesuai dengan UU ITE.

4. ISO/IEC 27001 adalah standar internasional yang membantu auditor dalam menerapkan Sistem Manajemen Keamanan Informasi (ISMS).

- **Memberikan Kerangka Keamanan Informasi:** ISO/IEC 27001 merekomendasikan penerapan kontrol keamanan yang ketat dan terorganisir. Auditor dapat menggunakannya sebagai referensi untuk menemukan masalah keamanan dan memastikan bahwa semua proses memenuhi standar internasional.
- **Mendukung Pematuhan Regulasi:** Organisasi dapat mematuhi peraturan terkait keamanan informasi, seperti perlindungan data pribadi dan keamanan data, dengan mengadopsi ISO/IEC 27001. Auditor memastikan bahwa organisasi mengikuti prosedur ini sesuai prosedur.

- Meningkatkan Keamanan Sistem dan Data: Panduan ISO/IEC 27001 memberikan pedoman untuk menangani risiko keamanan dan meningkatkan sistem perlindungan data. Auditor menilai apakah manajemen risiko organisasi sudah mengikuti pedoman tersebut dan memastikan bahwa langkah-langkah yang diperlukan telah diambil untuk melindungi informasi dari ancaman.

5. Seorang auditor TI mengevaluasi kontrol akses dengan:

- Menguji Autentikasi dan Otorisasi: Auditor memastikan bahwa sistem memiliki mekanisme autentikasi dan otorisasi, seperti password atau autentikasi dua faktor. Mekanisme ini hanya memungkinkan pengguna yang sah untuk mengakses data sensitif.
- Analisis Log Akses: Auditor menemukan aktivitas mencurigakan seperti akses tidak sah atau pola akses yang mencurigakan dengan melihat log akses. Mereka mencari bukti bahwa pengguna hanya mengakses informasi yang berkaitan dengan pekerjaan mereka.
- Peninjauan Kebijakan Kontrol Akses: Auditor memastikan bahwa kebijakan kontrol akses sesuai dengan standar dan diterapkan dengan konsisten. Mereka juga memastikan bahwa hak akses diberikan berdasarkan prinsip least privilege dan ditinjau secara berkala.

6. Teknik Pengujian Black-box dan White-box dalam Audit TI

- Black-box Testing: Metode ini memeriksa sistem dari sudut pandang luar tanpa memeriksa kode sumber. Setelah memasukkan input, auditor memeriksa apakah sistem menghasilkan output yang tepat. Teknik ini digunakan untuk menguji sistem fungsional pada tahap akhir pengujian.
- White-box Testing: Auditor memeriksa kode sumber untuk memeriksa jalur logika, validasi, dan proses internal aplikasi. Metode ini memungkinkan auditor

untuk melihat lebih dalam bagaimana sistem bekerja dan menemukan potensi kelemahan. Uji kotak putih biasanya dilakukan di awal proses pengembangan atau pengujian unit.

7. Audit berbasis risiko membantu auditor untuk fokus pada area yang memiliki dampak terbesar pada organisasi. Dengan memahami dan memprioritaskan risiko, auditor dapat:

- Alokasi Sumber Daya Lebih Efisien: Fokuskan sumber daya pada area yang memiliki risiko tinggi untuk mengurangi waktu dan biaya.
- Mendeteksi Risiko yang Signifikan: Menemukan risiko utama yang dapat menyebabkan kerugian besar bagi organisasi.
- Membantu Manajemen Risiko: Membantu organisasi menghadapi ancaman potensial dan menjaga keberlangsungan bisnis.

8. Wireshark adalah alat yang populer dalam audit TI, khususnya untuk memonitor lalu lintas jaringan. Berikut adalah cara kerja dan penggunaan utamanya:

- Cara Kerja: Wireshark menangkap dan menganalisis paket data di jaringan, memberikan gambaran menyeluruh tentang semua data yang melalui jaringan, termasuk sumber, tujuan, dan isi paket.
- Penggunaan dalam Audit: Wireshark membantu auditor menemukan aktivitas yang tidak biasa atau berbahaya di jaringan, seperti percobaan peretasan, kebocoran data, atau serangan DDoS, dengan analisis mendalam. Ini memungkinkan auditor untuk mengurangi risiko serangan keamanan dengan menemukan pola aktivitas.